VULNERABILITY ASSESSMENT AUDIT REPORT

FUTURE INTERNS - CYBER SECURITY TASK 1 (2026)

1. Executive Summary

This audit report presents the security findings from a read-only vulnerability assessment conducted on the public web application **testphp.vulnweb.com** as part of the Future Interns Cyber Security Internship (Task 1 - 2026). The assessment aimed to evaluate the target's public posture, identify security header omissions, assess service version disclosures, and outline risk-prioritized remediation strategies for management.

Target Domain	Assessment Type	Total Findings	Max Risk Level
testphp.vulnweb.com	Read-Only / Passive Audit	4 Config Weaknesses	Medium (CVSS ~5.3)

2. Assessment Scope & Rules of Engagement

To ensure legal compliance and avoid operational disruption, testing strictly adhered to a read-only passive scope. Active payload testing, login brute-forcing, and denial-of-service simulations were strictly prohibited.

Permitted In-Scope Activities	Prohibited Out-of-Scope Actions
Public HTTP Response Header Inspection	Authentication Bypass & Exploit Payload Execution
Passive Web Application Vulnerability Scanning	Automated Form Fuzzing & SQL Injection Testing
Service & Open Port Identification (Nmap)	Denial of Service (DoS/DDoS) & Rate Limit Stressing
Client-Side Metadata & Cookie Flag Auditing	Social Engineering or Spear-Phishing Exercises

3. Assessment Tools & Methodology

Security evaluation was conducted using industry-standard tools operating strictly in passive modes:

• **Browser Developer Tools:** Used for real-time client-side analysis of HTTP/HTTPS response headers, cookie flags (HttpOnly/Secure), and static script assets.

• **Nmap (Network Mapper):** Executed lightweight service version detection (nmap -sV -F) to discover open web ports and banner information.

• **OWASP ZAP (Zed Attack Proxy):** Utilized for passive traffic analysis to automatically flag missing browser protection headers and server disclosures.

4. Summary of Identified Vulnerabilities

ID	Vulnerability Finding	Severity	Category	Impacted Component

V-01	Missing Content Security Policy (CSP)	Medium	Security Header	HTTP Response Stream
V-02	Missing HTTP Strict Transport Security (HSTS)	Medium	Transport Security	HTTPS Enforcement
V-03	Missing Clickjacking Protection (X-Frame-Options)	Low	Security Header	UI Redirection
V-04	Server Software & Version Information Disclosure	Low	Info Disclosure	Server HTTP Header

5. Detailed Findings & Remediation Guidance

Finding V-01: Missing Content Security Policy (CSP)

Description: The web server does not issue a Content-Security-Policy header in its HTTP responses.
Business Risk: Without a valid CSP, malicious scripts executed via cross-site scripting (XSS) or untrusted third-party script tags cannot be restricted by modern browsers.
Remediation Code: Add the following header directive to the web server configuration:

> **Recommended Header Directive**
>
> Header set Content-Security-Policy "default-src 'self'; script-src 'self' https://trustedscripts.com; object-src 'none';"

Finding V-02: Missing HTTP Strict Transport Security (HSTS)

Description: The web application lacks the Strict-Transport-Security HTTP response header.
Business Risk: Users initiating first-time connections over plain HTTP remain vulnerable to SSL/TLS stripping attacks and unencrypted man-in-the-middle eavesdropping.
Remediation Code: Enforce HTTPS connections across all subdomains:

> **Recommended Header Directive**
>
> Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains; preload"

Finding V-03: Missing Clickjacking Protection (X-Frame-Options)

Description: Neither X-Frame-Options nor frame-ancestors directives are configured.
Business Risk: Attacker-controlled websites can render the application inside a transparent <iframe> overlay to trick users into executing unauthorized UI clicks.
Remediation Code: Restrict framing permissions to identical origin:

> **Recommended Header Directive**
>
> Header always set X-Frame-Options "SAMEORIGIN"

Finding V-04: Web Server Software Banner Disclosure

Description: The Server header explicitly discloses the web server software version (nginx/1.19.0 (Ubuntu)).
Business Risk: Providing exact version numbers assists external actors in researching target-specific known CVE vulnerabilities.

Remediation Directive: Suppress version output in web server configurations (e.g., server_tokens off; in Nginx).

6. Audit Evidence & Verification Screenshots

Visual evidence captured during the assessment is archived in the accompanying Evidence/ screenshot bundle:

Figure 1: Client-Side Response Headers Inspection (DevTools)

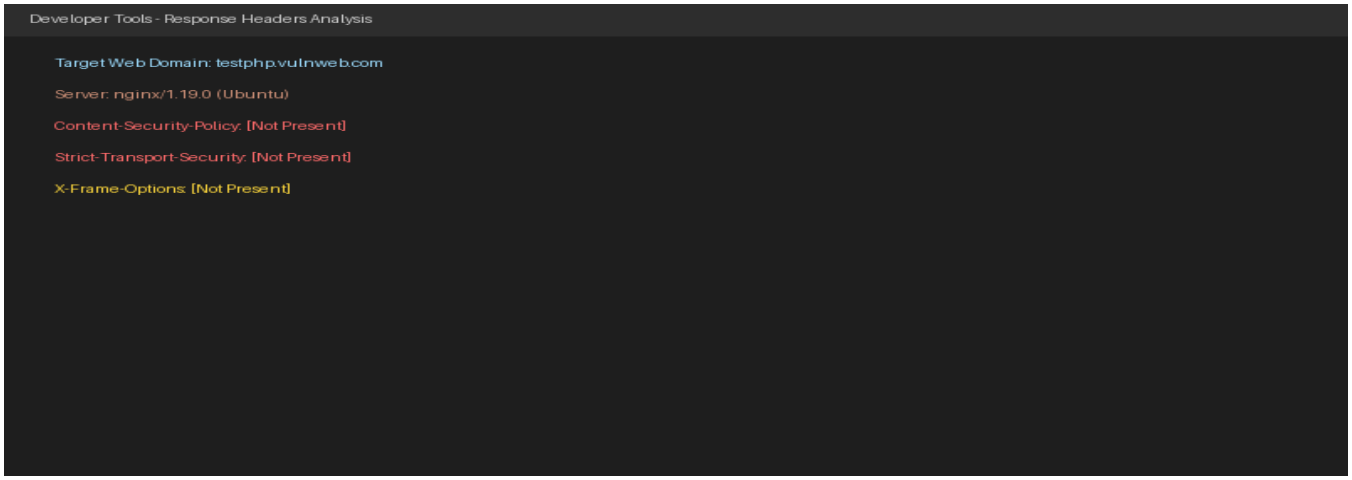
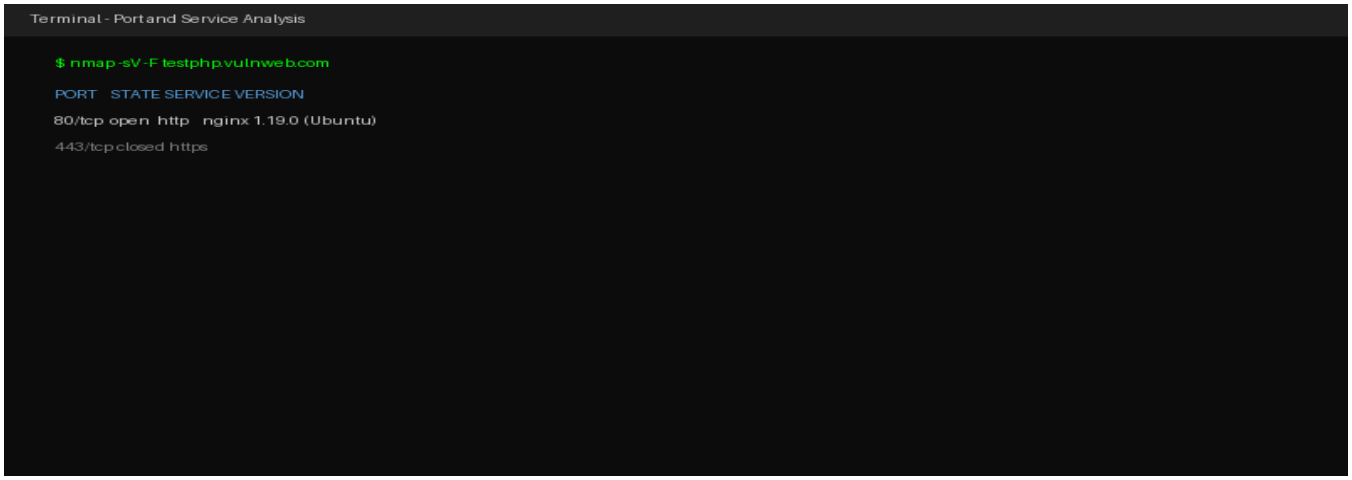


Figure 2: Passive Nmap Service & Port Analysis Output



7. Hardening Roadmap & Conclusion

Implementing security response headers and suppressing banner details will significantly elevate the baseline defenses of the web application. Management should prioritize deploying the **CSP** and **HSTS** headers within the upcoming maintenance cycle, followed by frame-ancestor rules and server configuration hardening.